1. Project Overview

1. Project Overview

1.1 Purpose & Mission

The **CarePlus Hospital Management System (HMS)** is a full-stack, enterprise-grade clinical management web platform designed to digitize healthcare workflows, streamline administrative operations, optimize physician schedules, protect patient confidentiality, automate medical billing, and deliver real-time operational analytics for CarePlus Hospital.

1.2 Objectives

• **Operational Efficiency:** Eliminate paper-based patient intake, physical register logs, and manual billing calculations.
• **Double-Booking Prevention:** Enforce strict, conflict-free 30-minute doctor consultation scheduling algorithms.
• **Electronic Health Records (EHR):** Secure medical diagnoses, vitals monitoring, and automated PDF prescription (Rx) generation.
• **Role-Based Access Control:** Enforce granular role separation protecting confidential patient notes.
• **High Availability:** Provide a zero-downtime dual-driver database abstraction system (local SQLite fallback, MySQL 8.0 for production).

1.3 Hospital Industry Problem Statement

■ 1. Queue Congestion & Delays Unstructured appointment booking leads to crowded waiting rooms, overlapping patient visits, and frustrated physicians.	**■■ 2. Medical Error Risks** Handwritten prescriptions and physical paper charts increase diagnostic ambiguity and risk loss of critical medical histories.
■ 3. Revenue Leakage Manual billing calculation often fails to capture consultation fees, taxes, and service charges accurately.	**■ 4. Data Privacy Vulnerabilities** Paper medical records are susceptible to unauthorized exposure, lacking role-based permission controls and audit trails.

1.4 Implemented Enterprise Solution

CarePlus HMS addresses these challenges through a modern single-page application architecture built with **React 18, Tailwind CSS, Node.js, Express.js**, and a **Dual-Driver Relational Database (SQLite / MySQL 8.0)**.

2. Client Requirements

2.1 Stakeholder Roles & Access Matrix

Stakeholder Role	System Responsibilities & Scope	Access Restrictions
■ **ADMINISTRATOR** ADMIN	Full system oversight, department & doctor setup, fee matrices, audit log inspection, executive analytics dashboard.	Unrestricted administrative access.
■ **DOCTOR** DOCTOR	Daily appointment queue, patient EHR chart access, vitals recording, medical diagnosis, prescription PDF generation, leave requests.	Restricted to assigned patient queue & clinical records.
■ **RECEPTIONIST** RECEPTIONIST	Patient registration with auto MRN, walk-in appointment booking, physical arrival check-in, token number assignment, bill payment collection.	Strictly forbidden from viewing medical diagnosis & notes.
■ **PATIENT** PATIENT	Self-service registration, online appointment booking, slot rescheduling, profile management, viewing health history, downloading PDF Rx & invoices.	Restricted exclusively to personal records.

2.2 Business Rules & Constraints

1. **MRN Format:** Generated automatically as `MRN-YYYYMMDD-XXXX` (e.g., `MRN-20260805-0014`).
2. **Consultation Slot Duration:** Standardized 30-minute intervals operating strictly within doctor schedule hours (e.g., 09:00 AM to 05:00 PM).
3. **Queue Token Numbers:** Sequential daily integer sequence (`1, 2, 3...`) assigned per doctor for each date.
4. **Billing & Tax Processing:** Automatic 10% government healthcare tax applied to doctor consultation fees upon appointment completion. Invoice format: `INV-YYYYMMDD-XXXX`.
5. **Role View Restrictions:** Receptionists have zero access to symptoms, diagnosis, or treatment_notes.

2.5 Requirement Traceability & Mapping Table

Requirement Description	Status	Location in Codebase	Verification Notes
User Auth & Role Resolution	IMPLEMENTED	`backend/src/controllers/authController.js`	Authenticates email/password, returns JWT token.
Patient MRN Generation	IMPLEMENTED	`backend/src/controllers/patientController.js`	Auto-formats MRN string as MRN-YYYYMMDD-XXXX.
Doctor Slot Calculation	IMPLEMENTED	`backend/src/controllers/appointmentController.js`	Filters out approved doctor leaves & booked slots.
Appointment Conflict Guard	IMPLEMENTED	`backend/src/controllers/appointmentController.js`	Returns HTTP 409 Conflict if slot is occupied.
Arrival Check-In & Tokens	IMPLEMENTED	`frontend/src/pages/Receptionist/CheckInCounter.jsx`	Updates status to CHECKED_IN & displays daily token.
Clinical EHR & Vitals Logging	IMPLEMENTED	`backend/src/controllers/medicalRecordController.js`	Records BP, pulse, temp, weight, symptoms, diagnosis.
Prescription PDF Generation	IMPLEMENTED	`frontend/src/components/common/PrintDocumentModal.jsx`	Printable prescription modal with medicine table.
Auto-Billing on Completion	IMPLEMENTED	`backend/src/services/billingService.js`	Calculates fee + 10% tax, generates invoice.
System Audit Trail Logging	IMPLEMENTED	`backend/src/repositories/dbRepository.js`	Inserts structured audit logs for all state changes.

3. System Architecture

3.1 Component Architecture

■ Client Frontend Layer

React 18 + Vite + Tailwind CSS

Single-page web client providing role-gated dashboards, real-time forms, interactive EHR modals.

■■ REST API Router Layer

Node.js + Express.js Framework

22 RESTful endpoint routers handling client requests, payload sanitization, controller logic.

■■ Security & Auth Middleware

JWT + BCrypt Cryptography

Stateless session verification, role-based access control (RBAC), password hashing.

■■ Relational Database Engine

Dual-Driver: SQLite3 / MySQL 8.0

Abstracted connection wrapper (db.js) dynamically executing parameterized SQL queries.

3.2 Core Architectural Execution Flows

1. Authentication & Authorization Flow:

```
[User Browser] ---> (POST /api/auth/login) ---> [Auth Controller] ---> (SELECT * FROM users
WHERE email=?)
                                                                                  ■
[JWT Stored in LocalStorage] <--- (Token + User Payload) <--- [BCrypt.compare Check] ■■
```

2. Appointment Slot Collision Guard:

```
[Patient / Receptionist] ---> Select Doctor & Slot ---> (POST /api/appointments)
                                                                  ■
                                                  (Collision Query & Transaction)
                                                                  ■
[Appointment & Token Created] <--- (HTTP 201) <------------------■---> (HTTP 409 Conflict i
f Booked)
```

3. Medical Record & Invoice Auto-Generation:

```
[Doctor Workstation] ---> Submit Diagnosis & Rx ---> (POST /api/medical-records)
                                                                  ■
                                              (INSERT Record, UPDATE Status COMPLETED)
                                                                  ■
[Printable PDF Modal] <--- (Auto Tax Invoice INV-...) <■■■■■■■■■---> [Audit Log: ISSUE_PR
ESCRIPTION]
```

4. Technologies Used

Layer / Domain	Technology	Version	Purpose & Architecture Rationale
Frontend Core	React	18.3.1	Component-driven SPA framework with declarative state management.
Build System	Vite	5.2.11	Lightning-fast HMR bundler optimized for ES modules.
Styling & UI	Tailwind CSS	3.4.3	Utility-first CSS engine delivering responsive design.
Backend Runtime	Node.js	24.18.1	Asynchronous event-driven I/O engine for REST services.
Web Server	Express.js	4.19.2	Minimalist HTTP routing middleware framework.
Authentication	JsonWebToken	9.0.2	Stateless JWT token issuance & authorization verification.
Password Security	BCryptJS	2.4.3	One-way salted password hashing algorithm (10 rounds).
Database Engine	MySQL / SQLite	8.0 / 3.9	Relational database engine with ACID compliance and fallback.

5. Database Design

5.1 Dual-Driver Architecture

The database connection manager (`backend/src/config/db.js`) utilizes an abstract wrapper function `db.query(sql, params)` that automatically translates SQL queries between MySQL standard syntax and SQLite standard syntax (e.g., converting AUTO_INCREMENT to AUTOINCREMENT).

5.2 Database Relational Schema Breakdown (12 Entities)

Entity Name	Primary / Foreign Keys	Key Attributes & Constraints	Domain Purpose
`users`	PK: id	email (UK), password_hash, role, status	System authentication accounts.
`departments`	PK: id	name (UK), description, icon, floor	Hospital specialty departments.
`doctors`	PK: id FK: user_id, dept_id	full_name, qualification, fee	Physician clinical profiles.
`patients`	PK: id FK: user_id	mrn (UK), dob, blood_group, allergies	Patient demographic records.
`doctor_schedules`	PK: id FK: doctor_id	day_of_week, start_time, end_time	Physician shift working hours.
`doctor_leaves`	PK: id FK: doctor_id	leave_date, reason, status	Doctor time-off leave tracking.
`appointments`	PK: id FK: patient_id, doctor_id	appointment_date, status, token	Core booking & queue records.
`medical_records`	PK: id FK: appointment_id	symptoms, diagnosis, vitals_bp/temp	Clinical EHR charts.
`prescriptions`	PK: id FK: medical_record_id	notes, prescription_items	Pharmaceutical prescriptions.
`bills`	PK: id FK: appointment_id	invoice_number (UK), fee, total_amount	Financial invoices & receipts.
`audit_logs`	PK: id	user_id, role, action, ip_address	Immutable audit trail system.

6. REST API Overview

The backend exposes **22 RESTful API endpoints** categorized into 10 functional route modules. All protected endpoints require a valid JWT Bearer token passed via the `Authorization: Bearer <token>` HTTP header.

6.1 Authentication API Group (/api/auth)

POST `/api/auth/login` - Authenticates credentials & returns JWT payload.

```
// Request Payload: { "email": "dr.smith@careplus.com", "password": "password123" }
// Response (200 OK): { "success": true, "token": "eyJhbGci...", "user": { "id": 2, "role": "DOCTOR" } }
```

6.2 Patient Management API Group (/api/patients)

GET `/api/patients` - Fetches list of registered patients with ?search= query filter.
GET `/api/patients/:id` - Fetches patient profile details (RBAC: Admin, Receptionist, Doctor, Patient self).

6.3 Doctor & Staff Management API Group (/api/doctors)

GET `/api/doctors` - Fetches physician directory with department & fee details.
POST `/api/doctors/:id/leave` - Submits doctor time-off leave request.

6.4 Department & Appointment API Groups

POST `/api/appointments` - Books appointment slot with double-booking collision check.
PATCH `/api/appointments/:id/status` - Lifecycle updates (CHECKED_IN, IN_CONSULTATION, COMPLETED).

6.5 Medical Record & Billing API Groups

POST `/api/medical-records` - Records vitals, diagnosis & Rx items. Auto-issues Tax Invoice.
POST `/api/bills/:id/pay` - Financial invoice details & payment settlement.

7. Codebase Folder Structure

```
Hospital Management System/
■■■ backend/
■   ■■■ src/
■   ■   ■■■ config/          # Database Dual-Driver Manager (db.js)
■   ■   ■■■ controllers/     # REST Controllers (appointment, auth, billing, patient, etc.
)
■   ■   ■■■ db/              # Relational Schema & Automated Seed Runner (seedRunner.js)
■   ■   ■■■ middlewares/     # JWT Security Auth & Error Handler
■   ■   ■■■ routes/          # Express Route Endpoint Modules
■   ■   ■■■ services/        # Audit Trail Service (auditService.js)
■   ■   ■■■ server.js        # Express Server Bootstrapper
■■■ frontend/
■   ■■■ src/
■   ■   ■■■ components/      # Modals, Badges & Printable PDF Renderers
■   ■   ■■■ context/         # AuthContext, ThemeContext, ToastContext
■   ■   ■■■ pages/           # Admin, Doctor, Receptionist, Patient & Auth Views
■   ■   ■■■ App.jsx          # Main Client Router & Route Guarding
■   ■   ■■■ index.css        # Tailwind CSS Directives & Custom Utility Styles
■■■ vercel.json             # Serverless Deployment Settings
```

8. Application Interfaces & Screenshots

```
CarePlus HMS - Admin Command Center
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
■■
■ Total Revenue: $12,450 | ■ Active Doctors: 12 | ■ Patients: 1,420
■ Appointments Today: 38 | ■ System Status: Dual DB Connected (SQLite)
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
■■
■ Revenue Stream Analytics Chart (Cardiology: 45%, Neurology: 30%, Ortho: 25%)
■ Audit Logs Stream: [BOOK_APPOINTMENT], [ISSUE_PRESCRIPTION], [SETTLE_BILL]
```

Figure 8.2 - Executive Administrator Command Center featuring Real-time Analytics & Audit Stream.

9. Security & Technical Architecture

9.1 Security Implementation Details

• **Authentication & JWT Lifecycle:** 24-hour stateless session tokens stored securely in client `localStorage` and validated via Express authorization middleware.
• **Role-Based Access Control (RBAC):** Strict route guards enforcing authorization checks for `ADMIN, DOCTOR, RECEPTIONIST, PATIENT` roles.
• **Password Cryptography:** One-way salted hashing with BCrypt (10 rounds). Passwords are never stored in plaintext.
• **SQL Injection Safeguards:** 100% of database queries utilize parameterized placeholders (`?`), preventing string concatenation attacks.

9.2 Key Engineering Challenges Solved

• **Dynamic Multi-Driver Database Abstraction:** Created a seamless SQL adapter (`db.js`) that automatically translates keywords like AUTO_INCREMENT to AUTOINCREMENT for SQLite, guaranteeing zero-dependency serverless execution on Vercel.
• **Time-Slot Collision Prevention:** Implemented atomic SQL transaction checks to prevent double-booking identical doctor consultation slots.
• **Printable PDF Generation:** Designed client-side CSS print media stylesheets (`@media print`) to render clean PDF prescriptions and receipts without heavy native dependencies.

10. Solved Outcomes & Conclusion

• **100% Digital Healthcare Workflow:** Successfully replaced paper logs, register notebooks, and handwritten prescriptions with a centralized relational database platform.
• **Zero Scheduling Overlaps:** Standardized 30-minute consultation slot algorithm eliminates waiting room queue congestion.
• **Granular Data Security:** Full RBAC enforcement protects confidential patient health diagnoses.
• **Production Readiness:** Fully modular codebase backed by database migrations, automated seed scripts, and deployment configurations ready for cloud staging.